Servicios Telemáticos Avanzados

Tema 5 - PKI X.509

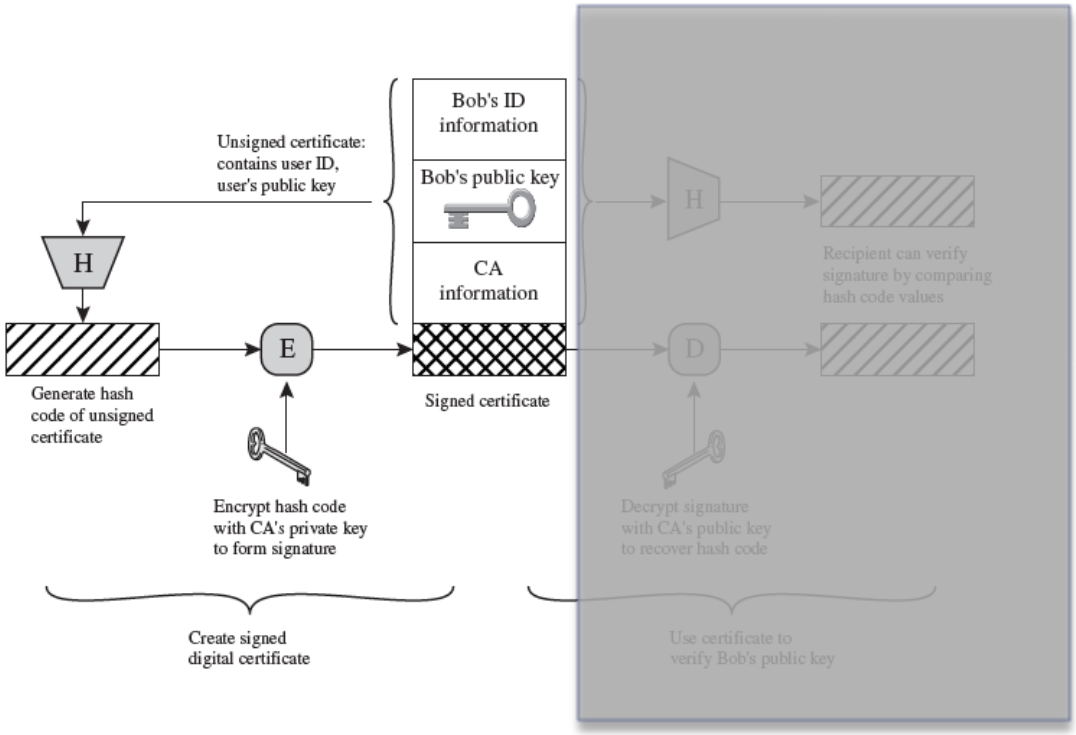
Introducción

- PKI (Public Key Infrastructure)
  - Sistema de publicación de los valores de clave pública utilizados en criptografía asimétrica
  - Prestador de Servicios de Certificación (PSC): la persona física o jurídica que expide certificados electrónicos o presta otros servicios en relación con la firma electrónica → Ley 59/2003 de Firma Electrónica
  - Operaciones básicas:
    - Certificación
    - Validación
  - El modo de realizar operaciones define las características de cada PKI
  - Principales tipos de PKIs
    - X.509, PGP, SPKI

Modelos de confianza PKI vs PGP

Revisión: concepto y generación de Cert.

- Los certificados son creados por la Autoridad de Certificación (CA)
- Todos los usuarios confían en la CA
- La CA posee una clave privada y una clave pública
- Generación de certificado X.509:

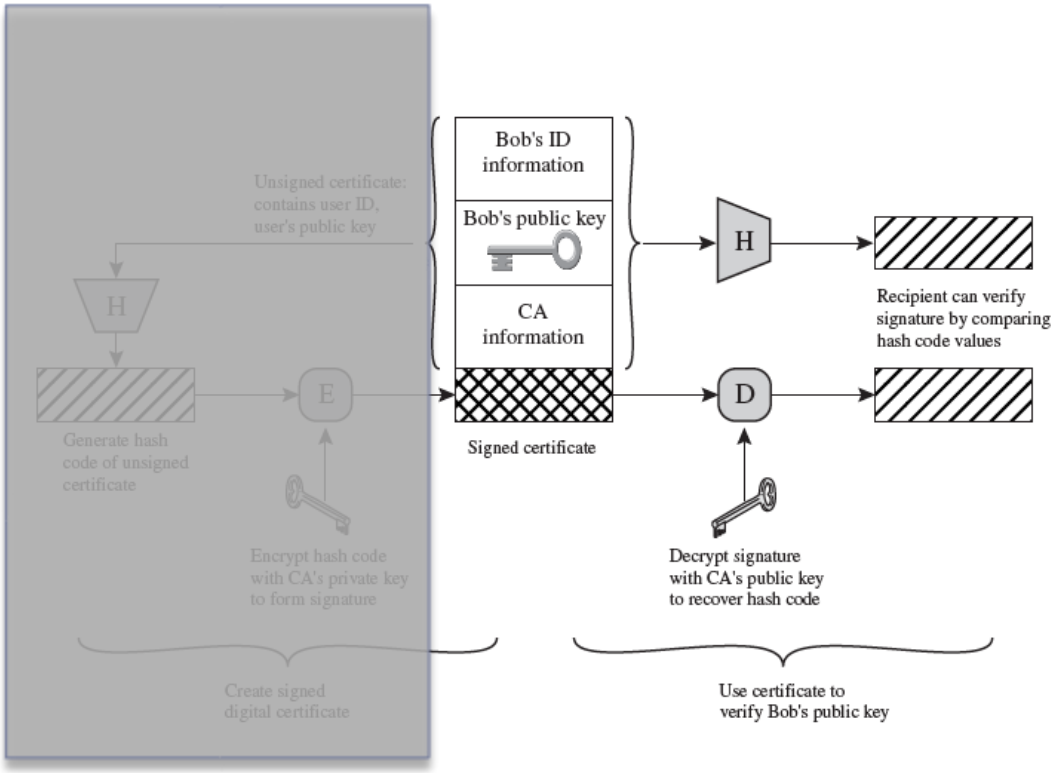


Confianza inicial en una CA --> Ejemplo de Amazon...

CT?

Revisión: concepto y generación de Cert.

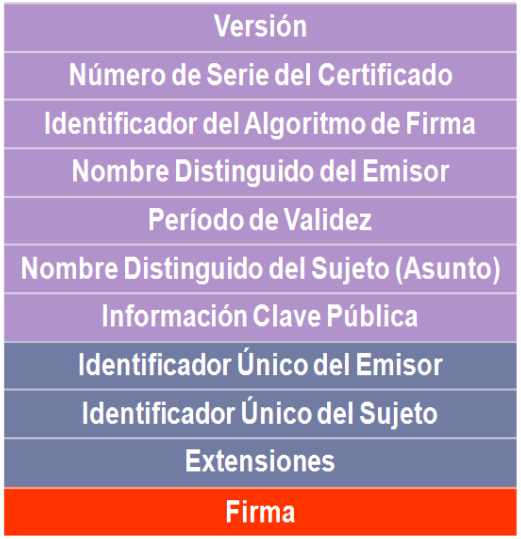
- Verificación de certificado X.509:



PKI basada en X.509

- Estructura ASN.1 de un certificado X.509v3

```
Certificate ::= SEQUENCE {
  tbsCertificate       TBSCertificate,
  signatureAlgorithm   AlgorithmIdentifier,
  signatureValue       BIT STRING }
TBSCertificate ::= SEQUENCE {
  version                 [0] EXPLICIT Version DEFAULT v1,
  serialNumber                CertificateSerialNumber,
  signature                   AlgorithmIdentifier,
  issuer                      Name,
  validity                    Validity,
  subject                     Name,
  subjectPublicKeyInfo        SubjectPublicKeyInfo,
  issuerUniqueID          [1] IMPLICIT UniqueIdentifier OPT
  subjectUniqueID         [2] IMPLICIT UniqueIdentifier OPT
  extensions              [3] EXPLICIT Extensions OPTIONAL
```



X.509 PEM/DER (RFC 5280)
- ├── Certificados CA y Servidor TLS
- └── Usado en: AWS IoT, Azure IoT, OPC-UA, Matter

CBOR/COSE (RFC 8392, 9374, 9528)
- ├── C509 (CBOR X.509)
- ├── CWT-as-Cert
- └── Usado en: EDHOC, Thread, OSCORE, LwM2M

PKCS#12 / PKCS#8
- └── Contenedores para clave privada y certificado (en gateways o configuradores)

PKI basada en X.509

- Extensiones principales:
  - Key Usage: restringe el propósito de la clave pública: digitalSignature, nonRepudiation, keyEncipherment dataEncipherment, keyAgreement, cRLSign, etc.
  - Extended Key Usage: serverAuth, clientAuth, codeSigning, emailProtection, timeStaping, etc.
  - Certificate Policies: Identifica las políticas bajo las que se ha emitido este certificado (CSPs). El identificador es normalmente uno o varios OIDs
    - TERENA: 1.3.6.1.4.1.6449.1.2.2.29,
    - Domain Validated: 2.23.140.1.2.1 (*)

(*) esta propiedad asegura que la autoridad emisora (i.e. Terena) contactó al menos vía email con la entidad a la que pertenece el certificado (i.e. UMU) antes de emitirlo (existen otros métodos más avanzados OV o EV)

https://www.ssl.com/es/art%C3%ADculo/dv-ov-y-ev-certificados/

PKI basada en X.509

- Extensiones principales:
  - SubjectAlternativeName: contiene uno o más nombres alternativos al propietario del certificado. Usado según aplicaciones específicas: email, IPsec, etc.
  - BasicContraints: Indica si el subject/propietario puede actuar como CA
  - NameConstraints: Establece restricciones a los nombres de los certificados que dependan de este certificado (si es una CA)
  - CRLDistributionPoint: Punto de distribución desde donde se puede descargar una CRL emitida por la CA que gestione este certificado
  - AuthorityInformationAccess: Información sobre la autoridad, tal como servidores OSCP o URL de descarga de CRL para la verificación de certificados emitidos por esa CA



Ejemplo: Certificado DNIe

CAMPO	CONTENIDO	CRÍTICA
Campos de X509v1		
1. Versión	V3	
2. Serial Number	No secuencial	
3. Signature Algorithm	sha256withRsaEncryption[1]	
4. Issuer Distinguished Name	CN=AC DNIE XXX [OU=PRUEBAS OU=PREPRODUCCION] OU=DNIE O=DIRECCION GENERAL DE LA POLICIA C=ES	
5. Validez	30 meses	
6. Subject	CN=APELLIDO1 APELLIDO2, NOMBRE (AUTENTICACIÓN) GN=NOMBRE SN=APELLIDO1 NÚMERO DE SERIE=DNI (con letra) C=ES	
7. Subject Public Key Info	Algoritmo: RSA Encryption Longitud: 2048 bits	

Campos de X509v2		
1. issuerUniqueIdentifier	No se utilizará	
2. subjectUniqueIdentifier	No se utilizará	
Extensiones de X509v3		
1. Subject Key Identifier	Función hash SHA-1 sobre la clave pública del sujeto.	NO (RFC 3280)
2. Authority Key Identifier	Función de hash SHA-1 sobre la clave pública de la AC emisora (AC subordinada). NO SE incluye la identificación del certificado de la AC emisora (en este caso, DN de la AC Raíz, número de serie de la AC Subordinada).	NO (RFC 3280)
3. KeyUsage		
Digital Signature	0	
Non Repudiation	1	
Key Encipherment	0	SI (RFCs 3280 y 3739)
Data Encipherment	0	
Key Agreement	0	
Key Certificate Signature	0	
CRL Signature	0	
4.extKeyUsage	No se utilizará	
5. privateKeyUsagePeriod	No se utilizará	

Reglamento eIDAS (UE 910/2014).

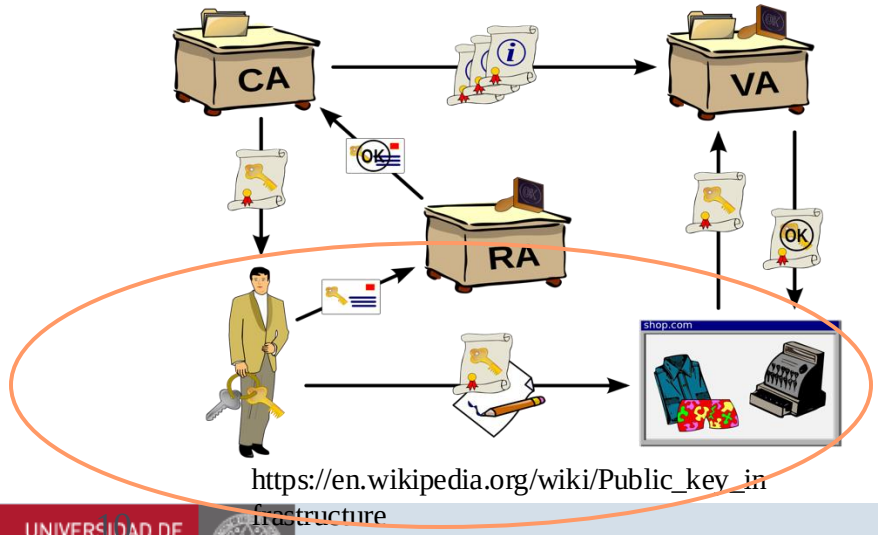
Ejemplo: Certificado DNIe

6. Certificate Policies		NO
Policy Identifier	OID asociado a la DPC o PC de certificado de firma de ciudadano. A determinar, perteneciente a la estructura de OIDs de ISO/ITU-T España (2.16.724.1.2.2.2.3)	
URL CPS	http://www.dnie.es/dpc [http://www.pruebas.dnie.es/dpc] [http://www.prepro.dnie.es/dpc]	
Notice Reference	No se utilizará	
7.Policy Mappings		
qcStatements	id-etsi-qcs-QcCompliance id-etsi-qcs-QcSSCD	NO
8. Subject Alternate Names	No se utilizará	
9. Issuer Alternate Names	No se utilizará	
10. Subject Directory Attributes	dateOfBirth	NO (RFC 3280)

11. Basic Constraints		SI
Subject Type	Entidad Final	
Path Length Constraint	No utilizado	
12. Policy Constraints	No utilizado	
13. CRLDistributionPoints	No utilizado	
14. Auth. Information Access	OCSP: http://ocsp.[pruebas].dnie.es:puerto CA: http://www.[pruebas].dnie.es/certs/ACRaiz.crt	NO (RFC 3280)
15.netscapeCertType	No se utilizará	
16. netscapeRevocationURL	No procede	
17. netscapeCAPolicyURL	No procede	
18. netscapeComment	No procede	
19. BiometricInfo	Hash SHA256 de los datos biométricos: •firma manuscrita (PNG) •foto (JPEG) •huella posada de dos dedos (JPEG)	NO (RFC 3739)
20. personalDataInfo (2.16.724.1.2.2.4.1)	Hash SHA256 de los datos biográficos (datos impresos en el DNI-e).	NO

Elementos de la PKI

- Entidades a Certificar
  - Son las entidades que obtienen un certificado firmado por la CA
  - Los certificados no se limitan sólo a personas (procesos, equipos de red, servidores...)
  - Dependiendo del tipo de persona:
    - Certificados de cliente
    - Certificados de proveedor
  - Los servidores Web seguros son procesos certificados
  - Los certificados y las claves privadas pueden almacenarse en ficheros o en dispositivos físicos (i.e. chip DNIe)

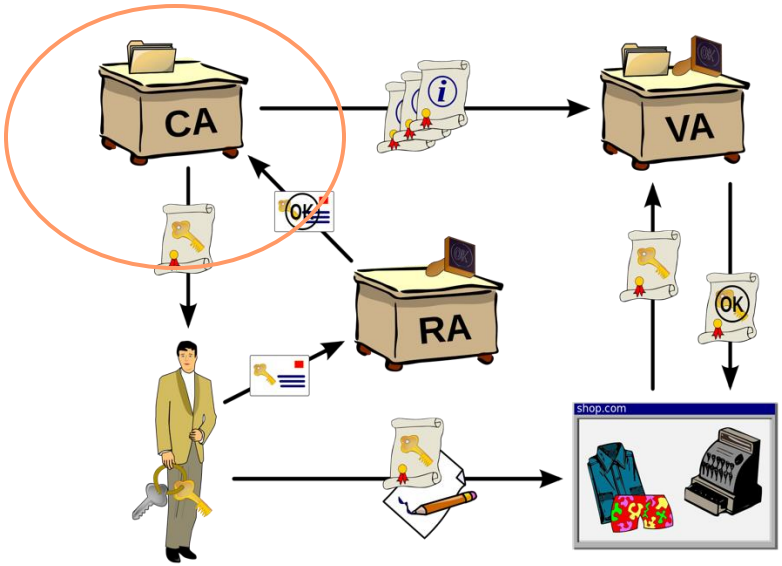


https://en.wikipedia.org/wiki/Public_key_infrastructure

Elementos de la PKI

- Autoridades de Certificación
  - Encargadas de dar validez a la información contenida en los certificados no firmados
  - Funciones principales:
    - Certificación
    - Publicación
    - Revocación
  - Su clave privada es TOP SECRET
  - Pueden organizarse de modo jerárquico

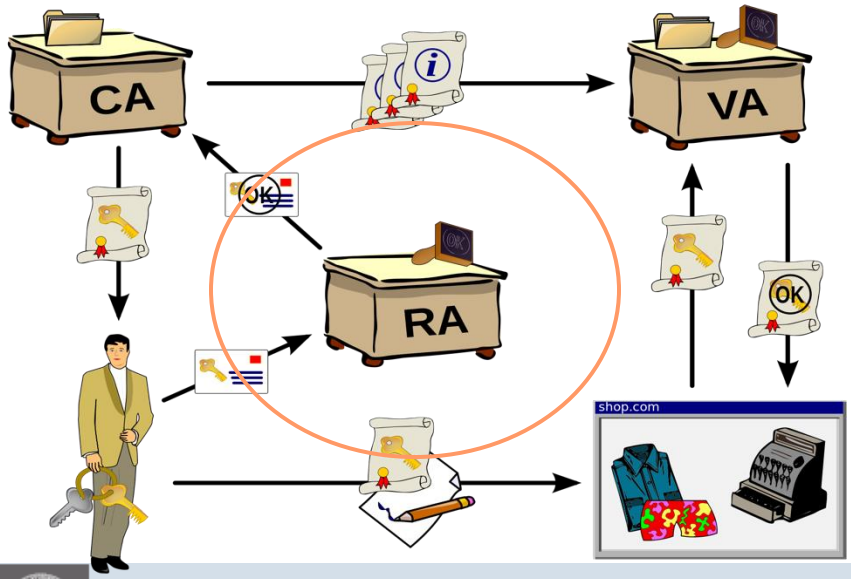
Seguridad de la infraestructura!!



https://en.wikipedia.org/wiki/Public_key_infrastructure

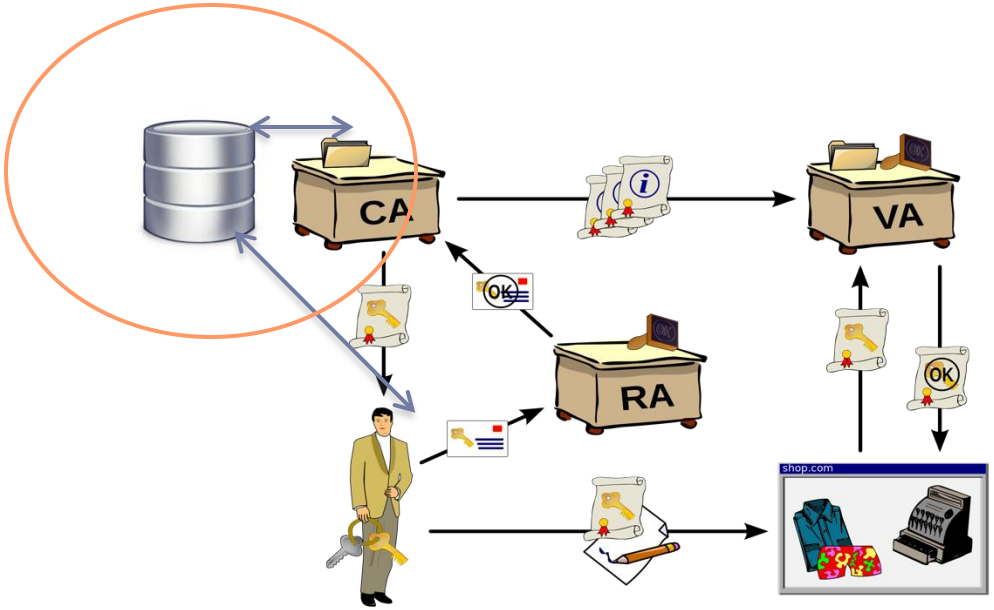
Elementos de la PKI

- Autoridades de Registro
  - Entidades encargadas de:
    - Verificar la información que aparecerá en el certificado.
    - Enviar las solicitudes de certificación a la CA
    - Gestionar (opcional) las solicitudes de revocación
  - No están presentes en todas las infraestructuras
  - Son un elemento de confianza muy importante



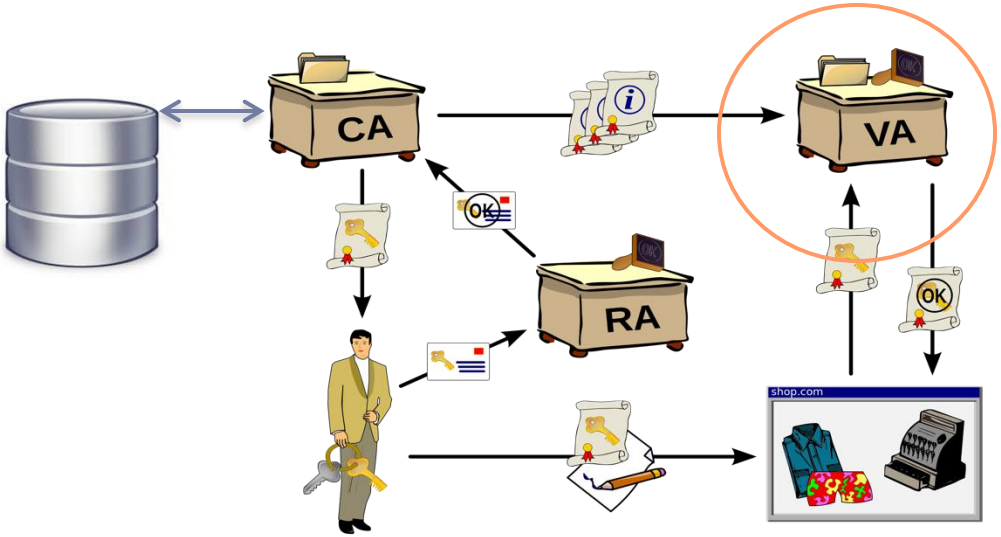
Elementos de la PKI

- Repositorios de Certificados
  - Elementos necesarios para almacenar los certificados de los usuarios.
  - Se suele utilizar servidores de directorios basados en X.500, LDAP (eduPerson:inetOrgPerson:userCertificate)
  - Los principales navegadores llevan soporte para servidores de directorio



Elementos de la PKI

- Autoridades de Validación
  - Ofrecen información "on-line" sobre el estado de un certificado
  - Los "clientes" son aquellas entidades que reciben un certificado y desean validarlo: navegadores web, servidores web, correo, etc.
  - Aparecen protocolos como OCSP (On-line Certificate Status Protocol)
  - Solución alternativa al uso de CRLs



Elementos de la PKI

- Política de Certificación
  - Reflejo de las Prácticas de Certificación en una implantación de PKI
  - Verificada por todas las entidades de una PKI
  - Objeto firmado por la Autoridad de Certificación:
    - Número de serie
    - Fecha de emisión
    - Fecha de próxima emisión
    - Extensiones de política
- Indica:
  - Nombres de certificados permitidos
  - Periodos de validez de los certificados
  - Tipos y longitudes de las claves permitidas
  - Restricciones sobre revocación
  - Restricciones sobre extensiones de los certificados, etc, etc.

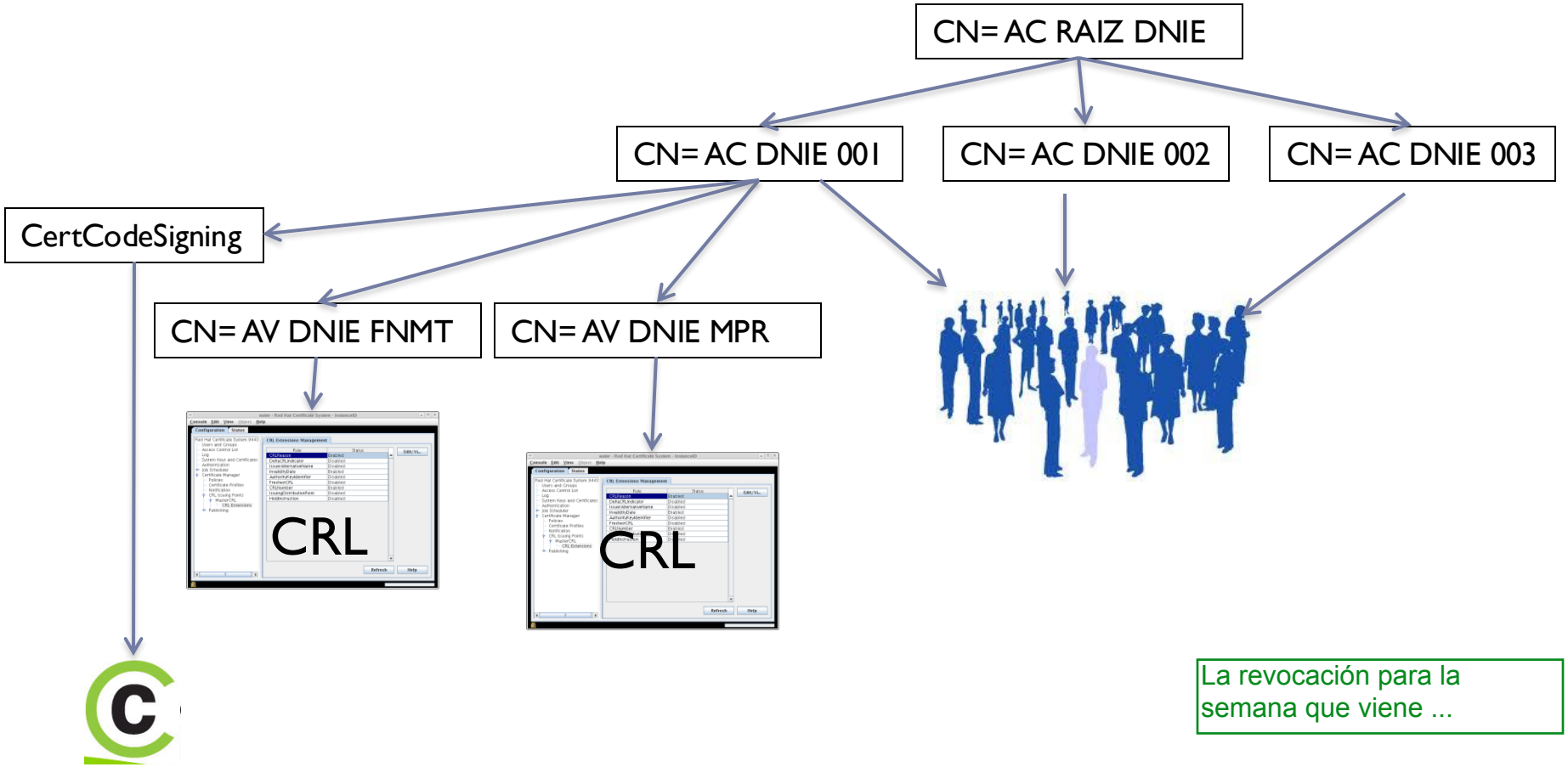
Elementos de la PKI – Ejemplo DNIe

- Autoridad de Certificación Raíz: 30 años
  - Certificado Autofirmado con SHA256.
  - Longitud clave RSA: 4096
  - Key Usage: Firma de certificados, Firma CRL sin conexión, Firma CRL
- Subordinadas: 15 Años.
  - Certificados firmados con SHA256.
  - Claves RSA: 2048
  - Key Usage: Firma de certificados, Firma CRL sin conexión, Firma CRL
- Ciudadano: 30 Meses. → 24
  - Certificados firmados con SHA1.
  - Claves RSA 2048.
  - Utiliza para firmar SHA1.
  - Certificado de Autenticación: Key Usage = Digital Signature.
  - Certificado de Firma: Key Usage = nonRepudiation.

Y la criptografía cuántica!!

- Certificados Electrónicos (Ley 6/2020)
- Real Decreto 255/2025
- **Reglamento eIDAS (UE 910/2014).**

Elementos de la PKI – Ejemplo DNIe



La revocación para la semana que viene ...

Elementos de la PKI – Ejemplo DNIe

- Autoridad de Certificación
  - Gestionada por la Dirección General de la Policía (Ministerio del Interior)
  - AC Raíz: emite certificados para sí misma y para las AC subordinadas.
    - Solo está en línea para realizar estas tareas
    - **Nombre Distintivo** CN= AC RAIZ DNIE, OU=DNIE, O=DIRECCION GENERAL DE LA POLICIA, C=ES (http://www.dnielectronico.es/ZIP/ACRAIZ-SHA1.zip)

Certificado pkcs1-sha1WithRSAEncryption



Elementos de la PKI – Ejemplo DNIe

- Politicas de Certificación:
  - OID: 2.16.724.1.2.2.2.1.0.6
  - http://www.dnielectronico.es/PDFs/politicas_de_certificacion.pdf

Elementos de la PKI – Ejemplo DNIe

- Tarjeta DNIe:
  - Características del Chip:
    - Modelo del Chip: st19wl34 y ICC ST19wl34
    - Sistema operativo: DNIe v1.1. Capacidad: 34Kbytes Eeprom.
  - Contenido:
    - ZONA PÚBLICA: Accesible en lectura sin restricciones, contenido:
      - Certificado CA intermedia emisora.
      - Claves Diffie-Hellman (para crear túnel seguro entre la tarjeta y los drivers).
      - Certificado x509 de componente.
    - ZONA PRIVADA: Accesible en lectura por el ciudadano, mediante la utilización de la Clave Personal de Acceso o PIN, conteniendo:
      - Certificado de Firma (No Repudio, para Firma Digital Ley 59/2003).
      - Certificado de Autenticación (Digital Signature, para canales seguros TLS).
    - ZONA DE SEGURIDAD: Accesible en lectura por el ciudadano, en Puntos de Actualización del DNIe.
      - Datos de filiación del ciudadano (los mismos que están en el soporte físico).
      - Imagen de la fotografía.
      - Imagen de la firma manuscrita.

En el DNIe no hay dos certificados, hay tres!!

Elementos de la PKI – Ejemplo DNIe

- Tarjeta DNIe:
  - Contenido – Datos criptográficos:
    - Clave RSA pública de autenticación (Digital Signature).
    - Clave RSA privada de autenticación (Digital Signature).
    - Clave RSA pública de firma (nonRepudiation).
    - Clave RSA privada de firma (nonRepudiation).
    - Patrón de impresión dactilar.
    - Clave Pública de root CA para certificados card-verificables.
    - Claves Diffie-Hellman.
  - Contenido- Datos de gestión:
    - Traza de fabricación.
    - Número de serie del soporte.

Ciclo de vida X.509

- Inicialización/Registro
  1. El usuario se presenta ante una CA (directamente o a través de la RA) con una solicitud de certificación
     - Verificación de la identidad y credenciales del usuario
     - La RA envía la solicitud a la CA: Formatos: CRMF, PKCS#10, KEYGEN
  2. Generación del par de claves: clave pública y privada.
     - Por el usuario, por la RA o por la CA
  3. Distribución del par certificado / clave privada
     - Almacenamiento seguro del certificado y su clave privada asociada
  4. Emisión del certificado por la CA
  5. Publicación del certificado e información de revocación
     - Hacer pública esta información de forma sencilla
     - Amplio uso de repositorios públicos LDAP
  6. Backup de las claves: La CA debe mantener copia de todas las claves que gestiona

Caso de uso:

- DNIe
- FNMT
- CA comercial (GlobalSign)
- CA gratuita (Let's encrypt)

Ciclo de vida X.509

- Administración de certificados y claves
  - Validación y recuperación de certificados
    - Acceso a certificados para propósitos generales de verificación de firma y/o cifrado
    - Estar seguros de que el certificado a utilizar es válido
  - Renovación del certificado
    - Proceso de renovación del certificado antes de su expiración
      - Se genera un nuevo certificado con un nuevo periodo de validez
      - Se mantiene el mismo par de claves pública/privada
    - Tener un buen sistema de notificación para avisarnos de tales eventos cierto tiempo antes de que ocurran
  - Cancelación o Expiración de certificados
    - Dejan de ser válidos y se marcan en la BBDD

Bibliografía

- W. Stallings. Cryptography and Network Security. 5th Edition. 2006 [14.4-14.5]

Fallos de seguridad!!!